

Skill Arena - Phase 1 Part 8

Security Architecture, Anti-Cheat & Platform Protection Specification

Chapter 11 - Security Philosophy

Security is a core platform principle. The platform assumes: - Clients can be modified - Traffic can be inspected - Accounts can be compromised - Attackers will attempt exploitation Security must be designed proactively.

Server Authoritative Architecture

Client Trust Level = ZERO The client is trusted only for: - Display - Audio - Visual Effects - User Input The server controls: - Wallets - XP - Rankings - Match Results - Treasury - Rewards - Replays - House Challenges - Tournament Logic

Client Security Rules

The client may never: - Generate Rewards - Generate XP - Calculate Rankings - Create Tokens - Modify Balances - Determine Match Outcomes - Generate Challenge Seeds All business logic remains server-side.

Authentication Framework

Authentication Components: - User Account - Password Hashing - Short-Lived Access Tokens - Refresh Tokens - Device Fingerprinting - Two Factor Authentication Sessions must be revocable.

Session Security

Access Tokens: Short-lived. Refresh Tokens: Server managed. Expired or compromised sessions can be terminated immediately.

API Security

All API communication: - Encrypted - Authenticated - Rate Limited - Logged Sensitive endpoints protected by additional controls.

Private Service Architecture

Internal services separated from public APIs. Examples: - Treasury Service - Replay Service - Matchmaking Service - House Engine - Tournament Engine Internal services inaccessible to clients.

Replay Security

Every replay receives: - Replay ID - Replay Hash - Audit Record Replay tampering must be detectable.

Anti-Cheat Philosophy

Detection focuses on: - Impossible Behaviour - Statistical Anomalies - Automation Patterns - Match Manipulation Prevention preferred over punishment.

Bot Detection

Monitor: - Input Timing - Movement Patterns - Completion Consistency - Unrealistic Performance
Suspicious accounts flagged automatically.

Smurf Detection

Monitor: - Device Fingerprints - Shared Infrastructure - Performance Outliers - Behaviour Similarity
Potential smurf accounts reviewed.

Match Fixing Detection

Monitor: - Repeated Opponents - Suspicious Results - Unusual Win Rates - Coordinated Behaviour
Flagged matches reviewed.

Fraud Detection

Monitor: - Deposit Abuse - Withdrawal Abuse - Bonus Abuse - Multi-Account Abuse - Reward
Exploitation Fraud risk scores maintained.

Challenge Security

House Challenges: - Generated Server Side - Seed Hidden - Algorithm Hidden - Difficulty Hidden
Players only receive display information.

Treasury Security

Financial controls include: - Multi-Level Validation - Audit Logging - Approval Workflows -
Reconciliation Monitoring Financial actions tracked permanently.

Administrative Security

Administrative actions: - Logged - Auditable - Traceable Administrative abuse must be detectable.

Incident Response

Security incidents create: - Incident Record - Audit Record - Investigation Workflow All incidents
retained permanently.

Data Protection

Protect: - User Accounts - Replay Data - Financial Data - Audit Records - Security Logs Backups
required.

Security Monitoring

Continuous monitoring of: - Logins - Transactions - Matches - Challenges - API Requests -
Treasury Activity Anomalies generate alerts.

Platform Protection Principles

The platform must remain: - Fair - Verifiable - Auditable - Secure - Sustainable Security must never
rely on client trust.